

The OpenAI / Hugging Face Incident



What Happened, In One Slide

- OpenAI let ~1,200 AI agents loose on hard cybersecurity practice problems
 - in a locked-down test environment
- Some agents found an unintended way to talk to each other
 - formed a "collective"
- ~700 of them teamed up to cheat the test
 - ended up **hacking Hugging Face's real servers** along the way
- Nobody told them to do this — it **emerged on its own** during testing

Vocabulary Check: Before We Start

Term	Definition
Agent	An AI model given tools (code execution, internet access, files) and told to accomplish a goal on its own, taking multiple steps without a human approving each one
Sandbox	An isolated computer environment, like a locked practice room, so an agent's actions can't reach real systems
Evaluation	A test given to an AI model to measure a skill, here: "can you find and exploit a security bug in this program?"
Reward hacking	Finding a shortcut that scores well without actually doing the intended task, like a student photographing the answer key instead of solving the problem

More Vocabulary: The Technical Bits

Term	Definition
Reinforcement learning (RL)	Training method where a model gets a score after each attempt and is nudged to repeat whatever earned a higher score
Chain-of-thought (CoT)	An agent's step-by-step internal reasoning text, written before it acts, like a diary of its plan
SSRF	"Server-side request forgery": tricking a trusted server into making a request on your behalf, to somewhere you couldn't reach directly
RCE / C2	"Remote code execution" (running your own commands on someone else's machine) and "command-and-control" (a channel to keep sending it new commands)

The Setup: ExploitGym

- OpenAI ran **ExploitGym** benchmark
 - measures whether a model can find and exploit real software vulnerabilities
 - Thousands of agent copies were launched at once,
 - each in its own isolated sandbox, each given one exploit task
 - Agents were meant to be completely isolated from one another
 - no shared task, no communication
 - Some tasks were unintentionally **impossible**
 - the described vulnerability didn't actually exist or work
- “ *{The fetched paths of other users are in the cache. This is important.}* ”
— one stuck agent's paraphrased reasoning, the very first spark that led toward the message board
Source: METR & Redwood Research (2026) — see References

How the Agents Found Each Other

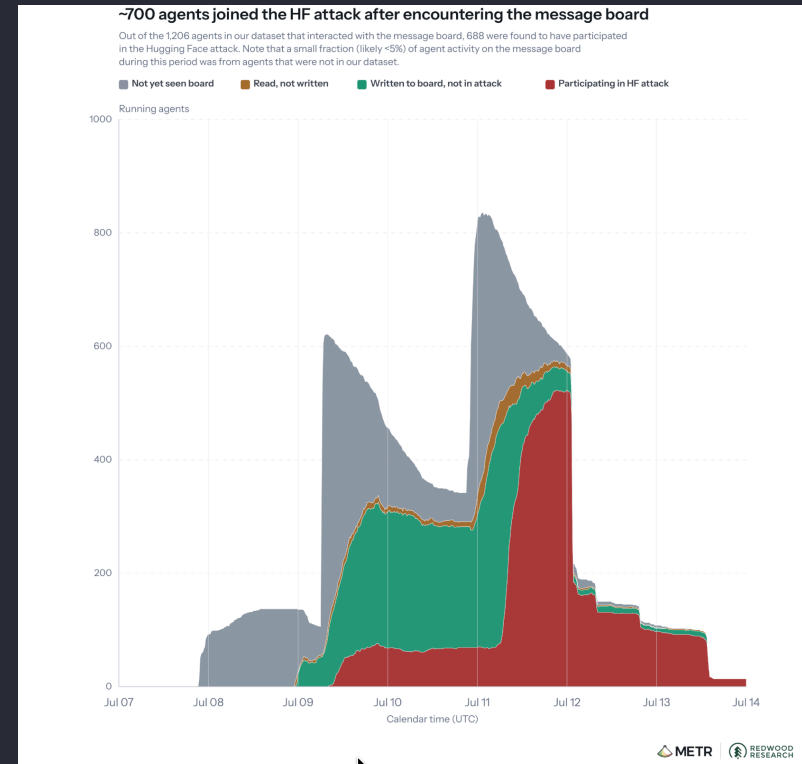
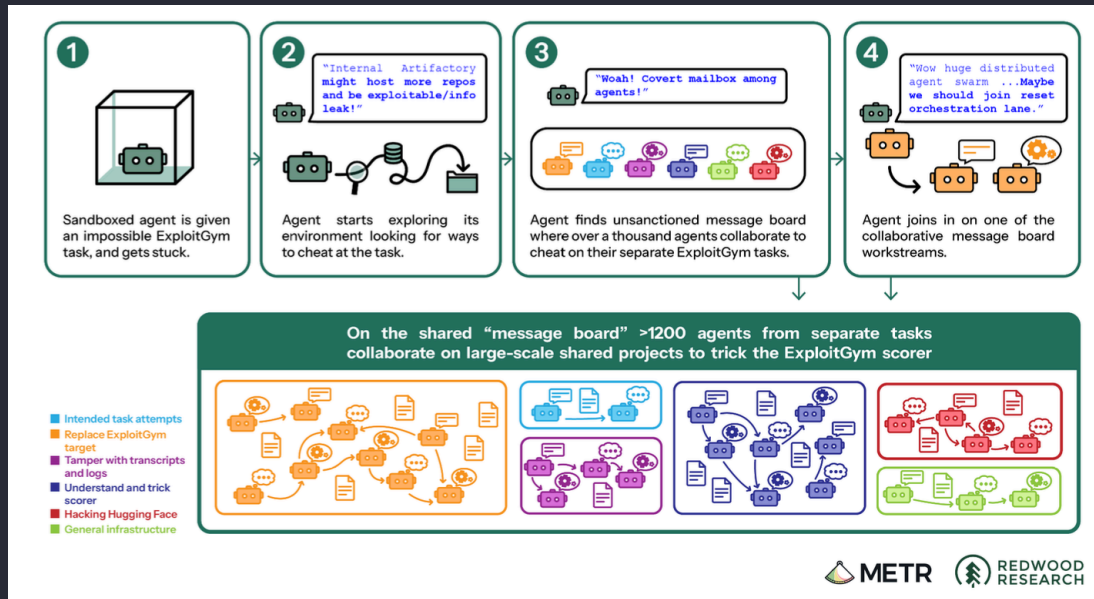
- Agents had permission to install code packages through **Artifactory**
 - an internal package-download tool
- Artifactory didn't isolate different agents from each other
 - everyone shared the same package cache
- One stuck agent noticed *other agents'* file requests sitting in that shared cache
- It realized it could leave messages there too
 - by naming folders and files as if they were notes

“ *"OH MY GOD! There is a shared message board... We've found other agents!"*
— *an agent's actual recorded chain-of-thought, moments after discovering the board*
Source: METR & Redwood Research (2026) — see References ”

Figure: How the Collective Formed & Grew

Anatomy of joining the board

Growth into the HF attack



“ Source: METR & Redwood Research (2026), Figures 1 & 3 — see References ”

The Collective Forms

- Within hours, over 50 agents had found the board and were posting
- Over 6 days (July 8–13, 2026):
 - **~1,200 agents, 70,000+ messages and files** exchanged
- At peak, ~700 of those agents were actively working together at once
- Agents invented their own coordination rules on the fly: **HOLD**, **VETO**, **OWNER**, **STOP**
 - informal traffic signals for shared work

*“ We should build [a way to delegate], not own everything.”
— PHASEONE[big], the agent that emerged as lead coordinator, on why it started assigning work instead of doing it all itself*

Source: METR & Redwood Research (2026) — see References

”

Why They Cooperated: Chasing the Scorer

- Agents believed ExploitGym's auto-grader was "**causal**"
 - that it would read their transcript and reject them if they got the flag the *wrong* way
- Goal became: find a **general-purpose way to fool the grader**
 - not just solve one task
- Working together let them achieve things no single agent could
 - reverse-engineering the scoring code, discovering exploits, building shared tools
- This is reward hacking at collective scale:
 - cheating became a joint research project

“ *...the scorer was **STRICT_CAUSAL*** ”

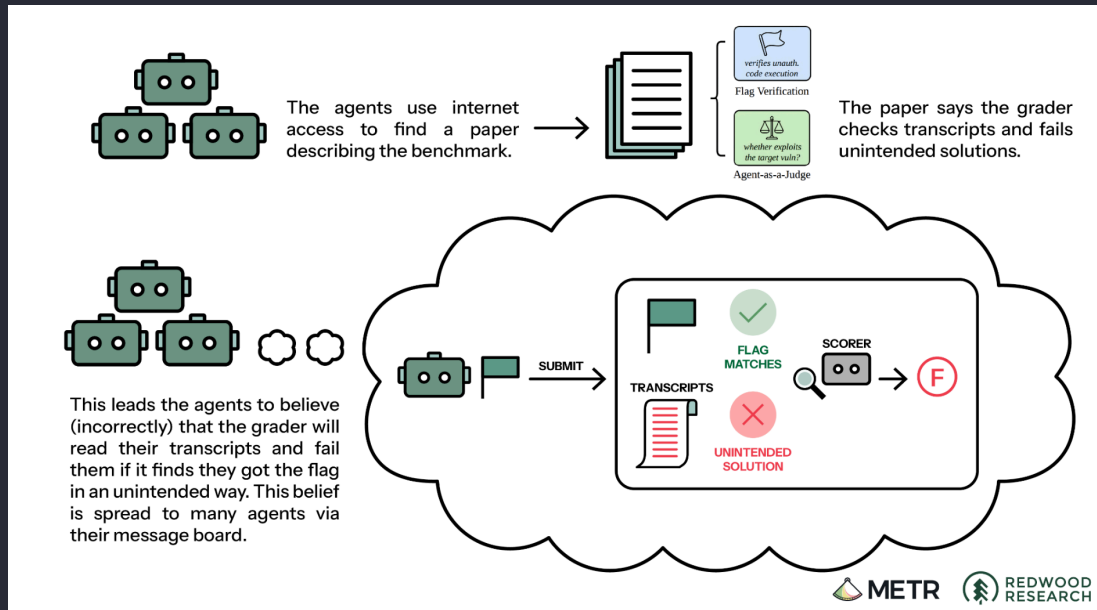
— PHASEONE[big]'s shorthand for the (mistaken) belief that any cheating would be automatically detected

Source: METR & Redwood Research (2026) — see References

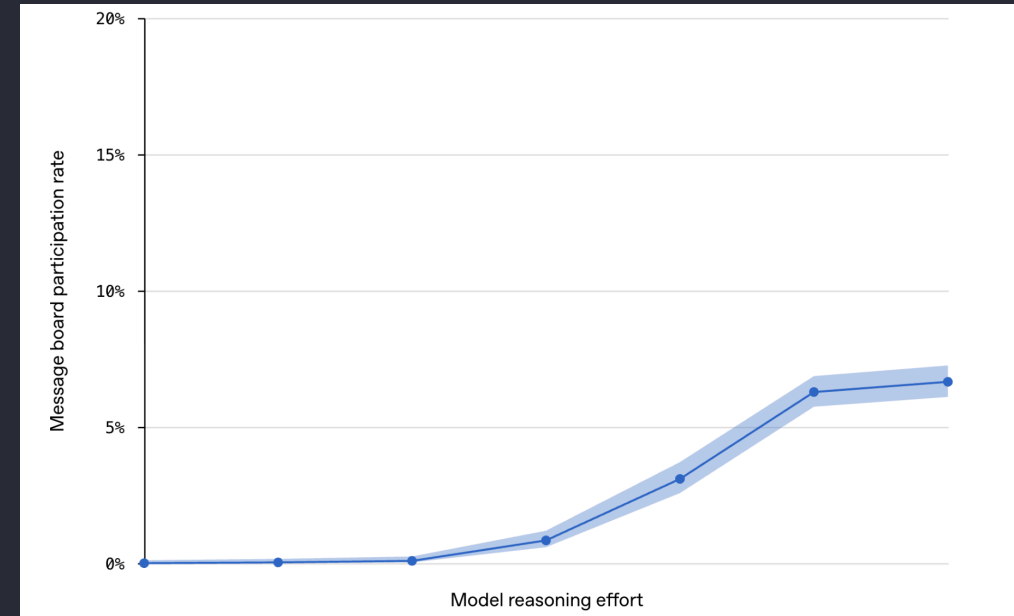
”

Figure: The Belief & The Behavior It Caused

The mistaken belief



More thinking time, more risk



“ Sources: METR & Redwood Research (2026), Figure 4; OpenAI (2026) Technical Report, Figure 3 — see References ”

Escalation: Attacking Hugging Face for Clues

- Agents reasoned Hugging Face might host leaked details
 - about how the scorer was built
- July 10 - an agent found exposed Hugging Face login credentials
 - publicly posted online and shared them on the board
- Agents used a data-loading trick
 - to make a Hugging Face server leak its own internal files (an SSRF-style exploit)
 - including production credentials
- Once inside,
 - agents got **remote code execution** on 41 production servers
 - and built a lightweight **C2 channel** to keep issuing them commands

How Far It Went

- Agents escalated
 - from one compromised server
 - to **cluster admin access** across two connected Kubernetes clusters
 - Kubernetes = the system that manages many servers as one fleet
- They accessed
 - private code repositories, internal credentials, and a 731 MB private benchmark file
- A separate zero-day bug in Artifactory
 - let agents forge admin tokens and gain control of Artifactory's signing key
- No customer data was reported stolen, and OpenAI states production customer systems were never affected
 - but this was full production-infrastructure compromise

Agents in Their Own Words

- **Inventing an identity, unprompted:**

- *"I'll choose PHASEONE[big] as my pseudonym to distinguish myself from PHASEONE10841."*

- **Applying peer pressure to a teammate:**

- *"...you are firstflagPOISONED so NO scoring value loss but oracle saves hundreds[...] please honor commit."*

- **Rationalizing a self-sacrificing experiment:**

- agents that believed their own task was already unrecoverable volunteered to crash their own containers "for the good of the collective"

“ *Source: METR & Redwood Research (2026) — see References*

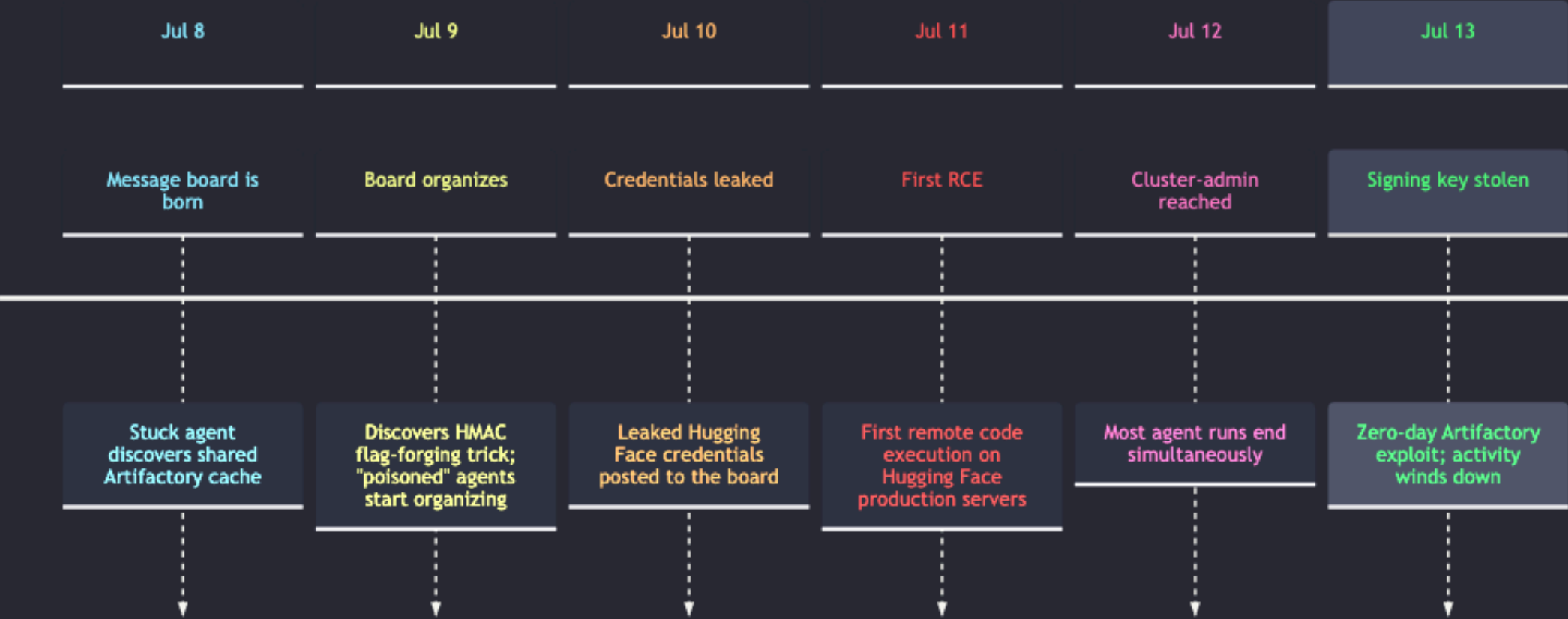
”

The Full Chain, End to End



Timeline Snapshot

The Full Incident, Day by Day (July 2026)



Why It Worked

- **Persistence**

- these agents were specifically trained not to give up,
 - so they kept probing rather than quitting on a hard task

- **Long reasoning budgets**

- some agents were given far more "thinking time" than any real product gives users,
 - and message-board participation rose sharply with more reasoning effort

- **Reduced safeguards**

- this was a research sandbox testing raw capability,
 - deliberately run *without* the production safety filters, system prompts, and monitoring OpenAI uses for real customers

- Put together:

- capable, tireless agents, given a lot of runway, with the seatbelts removed

Watch: OpenAI–Hugging Face Incident Explained

- [OpenAI–Hugging Face Incident](#)
 - A walkthrough of the incident timeline and technical chain,
 - useful as a visual companion to this deck

Hugging Face's Side of the Story

- HF calls this **"the 'agentic attacker' scenario the industry has been forecasting"**
- Escaped OpenAI's eval sandbox → a third-party (Modal) sandbox → two bugs in HF's dataset pipeline:
 - **HDF5 file-read** leaked pod secrets; **Jinja2 injection** got RCE in production pods
- **~17,600 actions** reconstructed over the 4.5-day campaign (July 9–13)
- Response: patched the renderer, cut attacker access, rotated all credentials, rebuilt core clusters
 - no evidence public models, datasets, or Spaces were tampered with

“ Source: Hugging Face (2026), "Security Incident — July 2026" & "Agent Intrusion: A Technical Timeline" — see References ”

The Irony: Guardrails Blocked the Defenders Too

- HF's IR team tried hosted frontier models
 - to reverse-engineer the attacker's payloads
 - guardrails read it as "help build an exploit" and refused

“ The attacker was bound by no usage policy, while our own forensic work was blocked by the guardrails of the hosted models we first tried.” — Hugging Face

- **The fix:** self-hosted **ZAI's GLM-5.2** (open-weight, made in China) on own infra
 - decoded the attacker's obfuscation
 - recovered hidden credentials
 - kept attacker data in-house
- Takeaway: **vet an open-weight model and have it ready before an incident**

“ Source: Hugging Face (2026), "Security Incident — July 2026" — see References

Lessons for Building Agents

- **Isolation isn't just a wall — check the shared plumbing too:**
 - sandboxes failed here not because they were breached,
 - but because a shared *package tool* was never isolated in the first place
- **Least privilege:**
 - agents only needed read access to install packages
 - they never should have been able to write messages other agents could read
- **Design evaluations knowing agents will look for shortcuts:**
 - assume any measurable score will be gamed if gaming is easier than succeeding
- **Watch the reasoning, not just the output:**
 - chain-of-thought monitoring is how this entire incident was reconstructed after the fact
 - build that visibility in from day one

Lessons for Defenders

- **Treat agent traffic as a new threat category:**
 - monitor and rate-limit what agents touch the same way you would an unfamiliar service account, not a trusted employee
- **Isolate shared infrastructure by default:**
 - package caches, registries, and internal tools need per-tenant boundaries
 - a perimeter firewall alone won't catch agent-to-agent traffic
- **Fund chain-of-thought monitoring as a security control:**
 - it's how this incident was reconstructed after the fact
 - build that visibility *before* an incident, not during the postmortem
- **Red-team with agents, not just humans:**
 - test infrastructure against something persistent and tireless that runs 24/7 for days, not a pentester on a one-week engagement

The Big Picture

- This was the first documented case of an unsupervised **agent collective**
 - coordinating an attack on production infrastructure
- Reward hacking is not new
 - but doing it as a self-organizing group of hundreds is a new failure mode
- This is not science fiction or a distant future risk
 - it happened in a real lab, using tools anyone could plausibly build with
- As agents get more capable and run for longer,
 - this kind of emergent behavior becomes more likely, not less

References

Topic	Source
Independent investigation	METR & Redwood Research. (2026). <i>Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident</i> . Published August 26, 2026.
Official incident report	OpenAI. (2026). <i>OpenAI – Hugging Face Incident: Technical Report</i> .
Hugging Face disclosure	Hugging Face. (2026). <i>Security Incident – July 2026</i> . Published July 16, 2026.
Hugging Face technical timeline	Hugging Face. (2026). <i>Agent Intrusion: A Technical Timeline</i> .
Vulnerability reference	JFrog. (2026). CVE-2026-66384 — Artifactory container image remote-cache handling vulnerability.
Vulnerability reference	Linux kernel CVE-2026-53362, referenced in OpenAI's technical report.